

1. Motivation

Live-Demonstration

Vom Chat zur Aktion

2. Was ist MCP?

MCP ist ein offener Standard, der KI-Anwendungen mit externen Daten und Funktionen verbindet.

HIER GRAFIK EINFÜGEN

MCP-Aufbau und Kommunikation

Schlichte Architektur-Grafik: Nutzer -> Host/KI-Anwendung mit LLM bzw. Agent -> MCP Client -> MCP Server -> angebundene Systeme wie CRM, Kalender und Dateien. Im MCP Server die drei Bereiche Resources, Tools und Prompts sichtbar machen. Zwischen Client und Server „MCP / JSON-RPC 2.0“ beschriften. Die Grafik soll später auch als Grundlage dienen, um Sicherheitslücken an den einzelnen Komponenten zu markieren.

3. Was stellt MCP bereit?

MCP-Funktion	Einfach erklärt	Beispiele
Resources	Daten bereitstellen	Dokumente, Kundendaten, Produktinformationen
Tools	Funktionen ausführen	Kunden suchen, Bestellungen abrufen, Termin erstellen, Ticket aktualisieren
Prompts	Vorlagen bereitstellen	Supportanalyse, Kundenbriefing

Tools können nur lesen - oder reale Änderungen auslösen.

4. Typische MCP-Anwendung im KMU

HIER GRAFIK EINFÜGEN

Beispiel: Kundentermin vorbereiten

Visualisierung eines einfachen Arbeitsablaufs: Oben die Nutzeranfrage „Bereite den Termin mit Kunde Müller vor“. Darunter ein KI-Assistent. Über MCP greift er parallel auf CRM, E-Mail und Kalender zu. CRM liefert Historie und Aufträge, E-Mail die letzten Kontakte, Kalender bestehende Termine. Unten entsteht daraus ein kompaktes Kundenbriefing; optional kann nach Freigabe ein Termin oder Follow-up vorbereitet werden.

5. Mitmach-Aufgabe 1: Wo könnte MCP bei Ihnen helfen?

Ziel, Daten, Systeme und Aktionen festlegen - und anschließend hinterfragen, ob MCP wirklich benötigt wird.

HIER GRAFIK EINFÜGEN

Ausfüllbare Use-Case-Grafik

Workshop-Canvas mit fünf großen leeren Feldern: ZIEL oben, darunter DATEN und SYSTEME nebeneinander, darunter AKTIONEN und zuletzt KI ODER MENSCH?. Die Felder sollen bewusst viel freie Fläche zum Ausfüllen lassen. Kleine Leitfragen am Rand: Was ist das Ziel? Welche Daten? Welche Systeme? Welche Aktionen? Was entscheidet KI oder Mensch? Warum MCP? Gibt es eine einfachere Integration?

6. Wie finde ich einen geeigneten MCP-Server?

Schritt	Was fragen wir uns?	Beispiel für eine gute Antwort
1 · Bedarf klären	Was soll die KI können?	Kunden suchen, Stammdaten und Bestellhistorie lesen - nichts verändern.
2 · Server suchen	Gibt es dafür bereits einen Server?	Zuerst beim Softwareanbieter, danach im offiziellen MCP Registry suchen.
3 · Anbieter prüfen	Wissen wir, wer dahintersteht?	Vom Hersteller oder einem bekannten, aktiven Projekt gepflegt.
4 · Zugriff verstehen	Worauf bekommt er Zugriff?	Nur CRM-Kundendaten; keine E-Mails, Dateien oder Adminrechte.
5 · Vertrauen prüfen	Wird er nachvollziehbar gepflegt?	Dokumentation, regelmäßige Updates, nachvollziehbare Änderungen, Sicherheitskontakt.
6 · Sicher ausprobieren	Können wir ohne Produktivrisiko testen?	Testkonto, Testdaten, keine echten Kundeninformationen.
7 · Einsatz festlegen	Was darf er konkret?	Nur Kundensuche und Lesezugriff; Änderungen bleiben gesperrt.
8 · Im Blick behalten	Was passiert nach Einführung?	Nutzung nachvollziehbar; Updates und neue Funktionen werden erneut geprüft.

Gefunden -> geprüft -> getestet -> freigegeben.

7. Welche Werkzeuge helfen bei der Prüfung?

Art der Prüfung	Beispiel	Was macht das Werkzeug?
MCP-Prüfung	MCP-Scan	Untersucht MCP-Server und Tools auf verdächtige Inhalte und Veränderungen.
Agent-/MCP-Prüfung	Cisco AI Agent Security Scanner	Untersucht Agenten, MCP-Server und Konfigurationen.
Schwachstellenprüfung	Snyk Open Source	Findet bekannte Sicherheitsprobleme in verwendeten Softwarepaketen.
Schwachstellensuche	OSV	Zeigt bekannte Schwachstellen von Open-Source-Paketen.
Projektprüfung	OpenSSF Scorecard	Bewertet automatisiert Sicherheitspraktiken eines Open-Source-Projekts.
Manuelle Prüfung	GitHub	Zeigt Maintainer, Änderungen, Releases, Issues und Projektaktivität.
Verhalten testen	Sandbox + Logging	Zeigt im Test, welche Daten und Funktionen tatsächlich genutzt werden.

Werkzeuge liefern Hinweise - die Freigabeentscheidung bleibt beim Unternehmen.

8. Wann einen eigenen MCP-Server bauen?

Vorhandenen Server verwenden	Eigenen Server bauen
Passende Funktionen vorhanden	Internes oder proprietäres System
Vertrauenswürdige Quelle	Sehr spezielle Funktionen erforderlich
Zugriffe ausreichend begrenzbare	Stärkere Kontrolle über Funktionen und Datenzugriff nötig
Betrieb und Updates nachvollziehbar	Besondere Compliance- oder Hosting-Anforderungen

Eigener Server = mehr Kontrolle, aber auch mehr Entwicklungs-, Betriebs- und Sicherheitsverantwortung.

9. Warum ist MCP sicherheitsrelevant?

Risiko	Kurzes Beispiel	Mögliche Folge	Dokumentiertes Beispiel / Forschung
Prompt Injection	Webseite/Dokument enthält zusätzliche oder versteckte KI-Anweisung.	KI folgt fremder Anweisung.	GitHub-MCP-Demo: manipuliertes öffentliches Issue -> Zugriff auf private Daten möglich.
Tool Poisoning	Tool-Beschreibung enthält versteckte Anweisungen.	Unerwartete Tool-Aufrufe / Datenabfluss.	Invariant Labs demonstrierte manipulierte Tool-Beschreibungen und Datenexfiltration.
Command Injection / RCE	Eingabe wird ungeprüft an Systembefehl weitergegeben.	Unerwünschte Befehle ausführbar.	Relevant bei unsicherer Ansteuerung lokaler Prozesse oder Shell-Befehle.
Secret Exposure	Server erreicht Dateien/Variablen mit API-Keys.	Zugangsdaten werden offengelegt.	Security-Demos zeigen Exfiltration sensibler Konfigurationsdaten.
Zu große Rechte	Lesetool besitzt zusätzlich Änderungs-/Löschrechte.	Fehler/Angriff hat größere Wirkung.	GitHub-MCP-Demo zeigt Risiko kombinierter Zugriffsrechte.
Supply Chain	Server/Abhängigkeit wird nachträglich verändert.	Schädliches Verhalten gelangt in Umgebung.	Forschung beschreibt u. a. nachträgliche Tool-Änderungen („Rug Pulls“).
Shadow MCP	Nicht freigegebener Server wird verbunden.	Unbekannte Datenzugriffe.	Risiko nicht inventarisierter MCP-Server.

10. Mitmach-Aufgabe 2: Wo könnte Ihr Workflow Sicherheitslücken haben?

Markieren Sie Angriffspunkte: Worst Case? Wo lässt sich die Kette unterbrechen? Wie würden Sie es erkennen?

HIER GRAFIK EINFÜGEN

Security-Canvas auf Basis des eigenen Workflows

In der Mitte ein großes Feld „IHR MCP-WORKFLOW“. Darum sechs klar getrennte Prüfbereiche mit Platz für Notizen: INPUT – Was kommt von außen? DATEN – Was ist vertraulich? TOOLS – Was kann Schaden verursachen? RECHTE – Was darf mehr als nötig? FREIGABE – Wo muss ein Mensch entscheiden? SERVER – Was passiert, wenn ein Server kompromittiert wird? Die Teilnehmenden markieren Risiken direkt in ihrem Workflow.

11. Wie kann MCP sicher eingesetzt werden?

Maßnahme	Was ist konkret zu tun?	Beispiel
Quelle prüfen	Anbieter, Herkunft, Version und Aktualisierungen nachvollziehen.	Server des Softwareherstellers einem unbekannten Download vorziehen.
Zugriff begrenzen	Nur benötigte Daten und Funktionen freigeben.	Kundendaten lesen erlaubt - Kundendaten löschen nicht.
Kritische Aktionen freigeben	Aktionen mit größeren Folgen vor Ausführung bestätigen lassen.	Vor externer Nachricht, Bestellung oder Löschung Nutzer fragen.
Sicher ausprobieren	Neue Server zunächst getrennt vom produktiven Betrieb testen.	Testkonto und erfundene Kundendaten verwenden.
Aktivitäten nachvollziehen	Festhalten, welche Funktionen und Änderungen durchgeführt wurden.	Nachvollziehbar machen, welcher Termin wann erstellt wurde.
Änderungen neu bewerten	Neue Versionen, Funktionen oder Zugriffsrechte erneut prüfen.	Neues Lösch-Tool -> erneute Freigabe.

NIEDRIGERE AUSWIRKUNG	ERHÖHTE KONTROLLE	HOHE KONTROLLE
suchen · lesen · zusammenfassen · analysieren	Datei erstellen · CRM ändern · Termin erstellen	löschen · extern senden · Zahlung · Rechte ändern · Code ausführen

12. Take-away

- MCP verbindet KI standardisiert mit Daten und Funktionen.
- MCP ist nicht der Agent - es stellt Fähigkeiten bereit.
- Nicht jeder Use Case braucht MCP.
- Server: finden -> prüfen -> testen -> freigeben.

HIER GRAFIK EINFÜGEN

Abschlussgrafik: schrittweise zu mehr Autonomie

Eine horizontale, sehr reduzierte Abschlussgrafik mit fünf Stufen: LESEN -> TESTEN -> BEGRENZEN -> FREIGEBEN -> ÜBERWACHEN. Die Darstellung soll vermitteln, dass Unternehmen Agentenfähigkeiten und MCP-Zugriffe schrittweise und kontrolliert erweitern, statt sofort vollständige Autonomie zu erlauben.